STHIROS · CYBER · DATA PRIVACY & PROTECTION ENGINEERING · LIFE SCIENCES

STHIROS
Strategy. Risk. Cyber. AI.

Turning 120+ controls across three geographies into one clean SOC 2 report

A global life sciences SaaS provider engaged Sthiros for a SOC 2 Type 2 assessment across 4 products and 3 geographies, delivering a clean report that unlocked regulated markets.



Client	Service	Sector	Geography
Global Life Sciences SaaS Provider	**SOC 2 Type 2 Assessment, Security, Availability & Confidentiality**	**Life Sciences, SaaS**	**India, USA, Portugal**

The Challenge:

When strong product can't close regulated deals alone

This SaaS provider ran four products on Azure across Chennai, Santa Clara, and Portugal, serving FDA and EMA regulated clients. Without an independently validated SOC 2 Type 2 report, high-value deals stalled in security review, or were lost entirely.

Market Access Friction

No SOC 2 report meant repeated friction in enterprise procurement reviews.

Multi-Geography Complexity

Enforcing controls consistently across 3 locations and 4 products was unproven.

Shared Responsibility Gap

CSOCs and CUECs governing subservice providers had never been validated.

Subservice Oversight Gap

Azure, Imperva, Acronis, GitHub, and ManageEngine sat outside formal mapping.

Inconsistent Control Posture

Controls were not uniformly applied across Chennai, Santa Clara, and Portugal.

Compliance Duplication

SOC 2 controls ran isolated from existing ISO 27001 and ISO 9001 frameworks.

The Solution:

A four-pillar transformation, built for a clean report

Sthiros ran a structured SOC 2 compliance transformation designed not just to achieve certification, but to build a sustainable governance engine across every product and location.

Every control was validated against AICPA Trust Services Criteria, with gaps remediated within the audit period itself rather than deferred to a re-audit.

The Methodology

1 End-to-End Control Validation

120+ controls mapped, tested, and validated against AICPA Trust Services Criteria across all four SaaS products and both primary delivery locations.

2 12-Month Operating Effectiveness Framework

The operating effectiveness framework was built and monitored from Day 1, ensuring evidence accumulation was disciplined and audit-ready at closure.

3 In-Period Remediation Model

Gaps identified during the audit cycle were remediated within the period itself, not deferred, the difference between a qualified report and a clean one.

4 Full Ecosystem Coverage

The complete control chain, subservice organisations, CSOCs, and CUECs, was covered, giving clients a validated end-to-end assurance picture.

What This Means

Compliance shortens the sales cycle.

Fix gaps within the audit period.

One framework, not five.

Outcomes

120+

Controls validated

Design and operating effectiveness confirmed across every domain.

12 Months

Full audit period covered

Operating effectiveness demonstrated continuously, not at a single point in time.

4

SaaS products covered

All products on Azure's single-tenant cloud brought within one clean report.

5

Subservice providers mapped

Azure, Imperva, Acronis, GitHub, and ManageEngine formally addressed.

Get in touch

Is your compliance posture proven, or just documented?

Speak to Sthiros about what a structured SOC 2 programme can unlock for your enterprise pipeline.

Connect with us:
sthiros.com

STHIROS
Strategy. Risk. Cyber. AI.